

DPIA — Analyse d'Impact relative à la Protection des Données

Plateforme Bertel 3.0 — Système d'Information Touristique (SIT) & CRM

Dernière mise à jour : 27 mai 2026

Version 1.0

Validé par le responsable de traitement

Préambule — caractère préventif. À l'analyse, le traitement Bertel ne figure pas formellement dans la liste des traitements pour lesquels une DPIA est obligatoire au sens du référentiel CNIL (pas de traitement à grande échelle de données sensibles, pas de profilage systématique, pas de surveillance de personnes vulnérables). Cette DPIA est néanmoins conduite à titre préventif au regard de la nature multi-ORG de la plateforme et du volume de données opérateurs et CRM traitées.

1. Description du traitement

1.1 Présentation générale

Nom du traitement : Bertel 3.0 — plateforme CRM et SIT mutualisée

Nature : application web (Next.js + Supabase) accessible aux agents d'Offices de Tourisme et structures SIT pour produire, qualifier et diffuser des informations touristiques.

1.2 Périmètre fonctionnel

- Référencement des établissements touristiques (hébergement, restauration, activités, itinéraires, événements).
- Gestion des comptes éditeurs et appartenance multi-ORG.
- CRM de la relation prestataires (demandes, comptes-rendus, animation réseau).
- Workflow éditorial : modération, historisation, publication.

- API publique pour diffusion des contenus auprès de sites partenaires.

1.3 Acteurs et rôles

Rôle	Acteur	Nature
Responsable du traitement principal	SPL OTI DU SUD	Éditeur et opérateur Bertel
Co-responsables / responsables conjoints	ORG partenaires (autres OTI / SIT)	Responsables de leur scope de publication
Sous-traitant hébergement BDD / Auth	Supabase Inc. (région primaire UE à documenter parmi eu-west-1 , eu-west-3 , eu-central-1 , eu-central-2 , eu-north-1)	DPA disponible, à signer via PandaDoc depuis le dashboard ; certifié ISO/IEC 27001 ; chiffrement AES-256 au repos et TLS en transit
Sous-traitant hébergement front	OVHcloud (France)	DPA OVHcloud en place ; engagements RGPD publics ; pas de traitement hors UE / US lorsqu'une zone UE est sélectionnée ; certifications ISO/IEC 27001:2022, 27017:2015, 27018:2019, 27701:2019 (périmètre non-US)
Référent RGPD interne	David Philippe — Manager SI	d.philippe@otisud.com — SPL OTI DU SUD n'a pas désigné de DPO au sens de l'Art. 37 RGPD

1.4 Volumes (ordre de grandeur)

- Comptes éditeurs : quelques dizaines (10–100 selon ORG actives).
- Objets touristiques référencés : ~1 000 à 10 000 entrées selon le périmètre.
- Contacts CRM : ~500 à 2 000 par ORG.
- Trafic API publique : variable, plusieurs milliers de requêtes / jour.

2. Finalités et bases légales

Finalité	Base légale	Justification
Production et diffusion d'information touristique	Mission d'intérêt public (Art. 6.1.e)	Mission de service public d'OTI — Code du tourisme L.133-3
Gestion des comptes éditeurs	Intérêt légitime (Art. 6.1.f)	Sécurité de la plateforme, traçabilité éditoriale
Animation du réseau prestataires (CRM)	Contrat (6.1.b) / Intérêt légitime (6.1.f)	Conventions de partenariat, mission OTI
Modération, historisation et traçabilité éditoriale	Mission d'intérêt public (6.1.e) / Intérêt légitime (6.1.f)	Qualité de l'information touristique publique ; responsabilité éditoriale et sécurité juridique selon le périmètre
Sécurité et logs	Intérêt légitime (Art. 6.1.f)	Protection des biens et des données
Conservation comptable et obligations sectorielles	Obligation légale (Art. 6.1.c)	Lorsqu'une obligation légale spécifique s'applique (ex. pièces comptables liées aux partenariats)

Conformité : les finalités sont déterminées, explicites et légitimes (Art. 5.1.b). Pas de traitement secondaire incompatible.

3. Données traitées

Catégorie	Données	Personnes concernées	Sensible
Identité éditeur	Nom affiché, email, avatar	Agents OTI / ORG	Non
Authentification	Hash password, JWT, IP, user-agent, date	Agents OTI / ORG	Non – sécurité critique
Préférences UI	Langue, fuseau, prefs JSON	Agents OTI / ORG	Non
Rôle et permissions	Rôle plateforme, ORG, permissions	Agents OTI / ORG	Non
Audit trail	UUID éditeur par action	Agents OTI / ORG	Non
Contact opérateur	Nom commercial, email, tél, adresse	Prestataires (PM ou PP)	Variable – pro principalement
Contact CRM	Nom, prénom, email, tél, organisation	Réseau de l'OTI	Non
Historique CRM	Demandes, commentaires, comptes-rendus	Réseau de l'OTI	Appréciation possible
Médias publiés	Photos, vidéos, EXIF	Variable	EXIF à neutraliser

Pas de données sensibles (Art. 9 RGPD) en collecte structurée. Pas de données pénales (Art. 10 RGPD). Pas de mineurs identifiés. Pas de profilage automatisé.

⚠ Risque champs libres CRM. Les zones de texte libre (commentaires, comptes-rendus, notes de suivi) peuvent involontairement contenir des données sensibles (santé, situation familiale, difficultés financières, conflit, appréciation subjective) saisies par un éditeur non sensibilisé. Ce risque est traité par une mesure organisationnelle explicite (voir §5.2) et une action prioritaire (voir §7.1).

4. Nécessité et proportionnalité

4.1 Principe de minimisation (Art. 5.1.c)

- **Données éditeurs** : seules les données indispensables à l'authentification et à la collaboration multi-ORG sont collectées. Pas de date de naissance, pas d'adresse personnelle, pas de numéro de téléphone privé.
- **Données opérateurs** : seules les coordonnées de contact professionnel sont publiées. Lorsque l'opérateur est une personne physique (auto-entrepreneur), seules les coordonnées qu'il a explicitement déclarées à des fins de publication sont utilisées.
- **Logs** : durée de conservation des logs Supabase Auth limitée selon la politique du sous-traitant ; logs applicatifs purgés au-delà de 90 jours.

4.2 Exactitude (Art. 5.1.d)

- Chaque éditeur peut modifier ses propres données de profil (nom, langue, préférences).
- Workflow de modération permet la correction collective des contenus.
- Les opérateurs peuvent demander la rectification de leur fiche via le canal CRM.

4.3 Limitation de la conservation (Art. 5.1.e)

- Durées détaillées dans le [Règlement RGPD](#) (§5).
- Anonymisation des comptes inactifs > 24 mois.
- Archivage des sauvegardes : 30 jours glissants (Supabase Cloud).

4.4 Information des personnes (Art. 13)

- Page [RGPD publique](#) accessible depuis l'application.
- Information au moment de la création de compte (banner ou page dédiée).
- Mention dans les conventions de partenariat ORG / opérateurs.

5. Mesures techniques et organisationnelles

5.1 Mesures techniques

Mesure	Description	Niveau
Chiffrement en transit	TLS de bout en bout (HTTPS, HSTS)	✓ En place (TLS Supabase et OVHcloud)
Chiffrement au repos	AES-256 des données client (Supabase) + sauvegardes chiffrées	✓ En place (documenté par Supabase)
Authentification forte	Supabase Auth (password + option OAuth), JWT signés	✓ En place ; MFA pour rôles privilégiés à activer
Contrôle d'accès	RBAC plateforme + RLS PostgreSQL par ORG et permission	✓ En place
Cloisonnement multi-ORG	Politiques RLS strictes, vérifications API (<code>api.current_user_*</code>)	✓ En place ; audit annuel à programmer
Journalisation	Logs Supabase Auth + audit trail (<code>object_version</code> , <code>pending_change</code>)	✓ En place
Gestion des sessions	JWT à durée limitée, refresh token, déconnexion explicite	✓ En place
Sauvegarde / restauration	Sauvegardes Supabase intégrées ; PITR disponible en option (plans Pro / Team / Enterprise – souscription à vérifier pour Bertel) ; tests de restauration trimestriels	🟡 Plan souscrit + tests à documenter
Mise à jour de sécurité	Application des CVE critiques sous 30j (Next.js, dépendances)	✓ Pratique en place – procédure à formaliser
Headers de sécurité	CSP, X-Frame-Options, Referrer-Policy	🟡 À auditer et documenter
Protection injection	Requêtes paramétrées (Supabase JS), validation serveur	✓ En place

Mesure	Description	Niveau
Métadonnées EXIF des médias	Neutralisation automatique des EXIF (GPS, appareil, date) avant publication via API publique – pipeline <code>/api/media/upload</code> (resize ≤ 2000 px + strip métadonnées via sharp)	✓ En place pour les nouveaux uploads ; backfill des médias antérieurs à planifier
Hébergement Supabase (UE)	Région primaire UE parmi <code>eu-west-1</code> Ireland, <code>eu-west-3</code> Paris, <code>eu-central-1</code> Frankfurt, <code>eu-central-2</code> Zurich, <code>eu-north-1</code> Stockholm	● Région retenue pour Bertel à documenter
Certification Supabase	ISO/IEC 27001 (certificat accessible depuis le dashboard Supabase pour les plans Team / Enterprise)	✓ Documenté par Supabase – copie à archiver
Hébergement OVHcloud (UE)	Zone de stockage UE : OVHcloud s'engage à ne pas traiter hors UE ni aux États-Unis	✓ Engagement public OVHcloud – sélection de zone à documenter
Certifications OVHcloud	ISO/IEC 27001:2022, 27017:2015, 27018:2019, 27701:2019 (périmètre non-US, couvrant VPS, Public Cloud Instances, Managed Relational Database, Object Storage, Managed Web Hosting)	✓ Documenté par OVHcloud – preuves à archiver
DPA sous-traitants	DPA Supabase (à signer via la procédure PandaDoc depuis le dashboard) ; DPA OVHcloud (en place pour le rôle de sous-traitant)	● Signature Supabase et archivage des deux DPA – action prioritaire

5.2 Mesures organisationnelles

- **Politique d'accès** : rôles attribués selon le principe du moindre privilège (`tourism_agent` < `super_admin` < `owner`).
- **Procédure d'arrivée / départ** : création / désactivation des comptes éditeurs par l'admin ORG.

- **Sensibilisation** : information des agents OTI sur les bonnes pratiques RGPD (mots de passe, partage de données).
- **Registre des activités de traitement (Art. 30 RGPD)** : tenu par le référent RGPD interne — formalisation à finaliser (voir §7.1).
- **Procédure de notification des violations de données (Art. 33-34 RGPD)** : analyse de l'incident, qualification du risque pour les droits et libertés des personnes concernées, notification à la CNIL **dans les 72 h après constatation** lorsque la violation présente un risque, information des personnes concernées lorsque le risque est élevé.
Documentation interne systématique de toute violation, qu'elle soit notifiée ou non.
- **Règle « champs libres CRM »** : interdiction de saisir dans les zones de texte libre (commentaires, comptes-rendus, notes) des données sensibles (santé, opinions politiques / religieuses / syndicales, origine, orientation sexuelle, données biométriques / génétiques), des données pénales, ou des appréciations subjectives excessives. Une mention d'aide à la saisie est affichée dans l'UI et reprise dans la formation des éditeurs.
- **Convention de responsabilité conjointe (Art. 26 RGPD)** : à formaliser entre SPL OTI DU SUD et chaque ORG partenaire (voir §7.1, action prioritaire).
- **Revue annuelle** : la présente DPIA est revue chaque année et à chaque évolution majeure.

6. Analyse des risques pour les personnes concernées

Trois familles de risques sont analysées selon la méthode CNIL :

6.1 Accès illégitime aux données

SOURCES DE RISQUE

- Compromission d'un compte éditeur (mot de passe faible, hameçonnage).
- Faille technique côté Supabase ou Next.js.
- Erreur de configuration RLS exposant des données d'une ORG à une autre.
- Sous-traitant compromis.

IMPACTS POTENTIELS SUR LES PERSONNES

- Divulcation de contacts CRM (atteinte à la vie privée des contacts du réseau).
- Divulcation de coordonnées personnelles d'opérateurs auto-entrepreneurs.
- Atteinte à la réputation de l'OTI / d'un partenaire ORG.

VRAISEMBLANCE

Moyenne

GRAVITÉ

Moyenne

RISQUE BRUT

Modéré

MESURES DE MITIGATION

- Authentification Supabase Auth avec politique de mot de passe ; MFA recommandée pour les rôles `owner` / `super_admin` (à déployer).
- RLS PostgreSQL avec tests automatisés de non-régression.
- Audit régulier des permissions et des politiques RLS.
- Veille CVE et application rapide des correctifs.
- Contrat de sous-traitance (DPA) signé avec Supabase et OVH.

Niveau de risque résiduel : **Faible**

6.2 Modification non désirée des données

SOURCES DE RISQUE

- Erreur humaine d'un éditeur (suppression, modification erronée).
- Action malveillante interne (rare mais possible).
- Bug applicatif (régression, mauvaise validation).

IMPACTS POTENTIELS SUR LES PERSONNES

- Diffusion d'informations erronées sur un opérateur (préjudice professionnel).
- Perte d'historique relationnel CRM (préjudice de gestion).
- Confusion d'identité (mauvais rattachement ORG).

VRAISEMBLANCE

Moyenne

GRAVITÉ

Faible-Moyenne

RISQUE BRUT

Modéré

MESURES DE MITIGATION

- **Audit trail systématique** : chaque modification est tracée dans `object_version` et `pending_change` avec horodatage et identifiant de l'auteur.
- **Workflow de modération** : les modifications sensibles passent par un état `pending_change` revu avant publication.
- **Historisation des versions** : permet de revenir à un état antérieur (rollback).
- **Tests automatisés** : suite EXPLAIN ANALYZE et tests d'intégration sur les fonctions API.
- **Validation côté serveur** : contraintes PostgreSQL + RLS + vérifications applicatives.

Niveau de risque résiduel : **Faible**

6.3 Disparition des données

SOURCES DE RISQUE

- Sinistre Supabase Cloud (incident majeur infrastructure).
- Sinistre OVH Cloud (incendie, indisponibilité prolongée – cf. SBG 2021).
- Suppression accidentelle par un administrateur.
- Action malveillante (ransomware côté éditeur).

IMPACTS POTENTIELS SUR LES PERSONNES

- Perte de l'historique CRM (préjudice de continuité de service).
- Perte de l'audit trail (préjudice de traçabilité, possible non-conformité éditoriale).
- Indisponibilité de la plateforme (préjudice opérationnel pour les ORG et les opérateurs).

VRAISEMBLANCE

Faible

GRAVITÉ

Moyenne-Élevée

RISQUE BRUT

Modéré

MESURES DE MITIGATION

- **Sauvegardes Supabase** automatiques, rétention 30 jours, Point-in-Time Recovery selon plan.
- **Export régulier** : possibilité d'export SQL périodique stocké hors Supabase (à industrialiser).
- **Redondance multi-zone** Supabase Cloud UE.
- **Procédure de restauration documentée** : runbook SQL (`docs/SQL_ROLLOUT_RUNBOOK.md`).
- **Information sur les sauvegardes** auprès des ORG partenaires.

Niveau de risque résiduel : **Faible à modéré** (dépend du niveau d'industrialisation des exports externes – point d'amélioration identifié)

7. Synthèse des risques et plan d'action

Risque	Vraisemblance	Gravité	Niveau résiduel	Actions de suivi
Accès illégitime	Moyenne	Moyenne	Faible	Déployer MFA pour owner/super_admin ; audit RLS annuel
Modification non désirée	Moyenne	Faible-Moyenne	Faible	Continuer la couverture de tests sur les fonctions API
Disparition des données	Faible	Moyenne-Élevée	Faible-Modéré	Industrialiser un export externe régulier ; documenter le PCA

7.1 Actions correctives priorisées

#	Action	Échéance	Responsable
1	✓ Livré — Neutralisation automatique des métadonnées EXIF des nouveaux uploads via <code>/api/media/upload</code> (sharp, strip EXIF/IPTC/XMP + <code>resize ≤ 2000 px</code>). Reste à planifier : backfill des médias antérieurs.	Livré T2 2026 · Backfill : T4 2026	Équipe SI
2	Formaliser une convention de responsabilité conjointe (Art. 26 RGPD) avec chaque ORG partenaire : information des personnes, exercice des droits, sécurité, gestion des incidents / violations, durées de conservation, responsabilités éditoriales, pilotage des sous-traitants	T3 2026	Référent RGPD + Direction
3	Déployer la règle « pas de données sensibles dans les champs libres CRM » : mention d'aide à la saisie dans l'UI, formation des éditeurs, contrôle a posteriori	T2 2026	Référent RGPD + équipe produit
4	Signer et archiver les preuves sous-traitants : signature du DPA Supabase via la procédure PandaDoc accessible depuis le dashboard ; archivage du DPA OVHcloud, du certificat ISO/IEC 27001 Supabase (dashboard plans Team / Enterprise) et des certifications ISO/IEC 27001:2022, 27017:2015, 27018:2019, 27701:2019 OVHcloud ; documentation de la région primaire Supabase et de la zone OVH retenues pour Bertel ; revérification annuelle des sous-traitants ultérieurs	T2 2026	Référent RGPD
5	Activer la MFA Supabase pour les rôles <code>owner</code> et <code>super_admin</code>	T3 2026	Référent RGPD + équipe SI
6	Mettre en place un export SQL externe hebdomadaire vers stockage chiffré tiers	T3 2026	Équipe SI
7	Auditer et documenter les headers de sécurité (CSP, HSTS, X-Frame-Options, Referrer-Policy)	T2 2026	Équipe SI

#	Action	Échéance	Responsable
8	Industrialiser et documenter les tests de restauration trimestriels	T4 2026	Équipe SI
9	Formaliser le registre des activités de traitement (Art. 30 RGPD)	T2 2026	Référent RGPD
10	Information / formation RGPD des éditeurs ORG partenaires	T3 2026	Référent RGPD

8. Consultation des parties prenantes

- **Personnes concernées** : information par la page [RGPD publique](#). Les éditeurs sont informés à la création de compte. Les opérateurs et contacts CRM sont informés lors du premier contact.
- **Référent RGPD interne** : la présente DPIA est rédigée et validée par le référent RGPD interne (David Philippe).
- **Sous-traitants** : les DPA Supabase et OVH ont été examinés.
- **CSE** : aucun CSE n'est encore en place chez SPL OTI DU SUD. L'organisation s'engage à présenter Bertel et la présente DPIA dès l'installation de l'instance.
- **Autorité de contrôle (CNIL)** : la consultation préalable (Art. 36 RGPD) n'est pas requise dans la mesure où les risques résiduels sont évalués comme faibles à modérés et maîtrisés.

9. Validation

Avis du responsable de traitement : au regard des éléments documentés à ce stade, le traitement Bertel présente un **niveau de risque résiduel maîtrisé, sous réserve de la mise en œuvre effective des actions correctives identifiées au §7.1**. La présente analyse ne dispense pas :

- de la **tenue du registre des activités de traitement** (Art. 30 RGPD) ;
- de la **formalisation des relations avec les ORG partenaires** par une convention de responsabilité conjointe (Art. 26 RGPD) ;
- de la **vérification documentaire continue des sous-traitants** (Art. 28 RGPD – DPA, certifications, sous-traitants ultérieurs, régions d'hébergement).

Aucune consultation préalable de la CNIL (Art. 36 RGPD) n'est requise à ce stade.

Rôle	Nom	Date	Validation
Référent RGPD interne	David Philippe	2026-05-27	✓ Validé
Responsable du traitement	SPL OTI DU SUD (représentée par la direction)	2026-05-27	✓ Validé

10. Suivi et révision

La présente DPIA fait l'objet d'une **révision annuelle** et est **réévaluée systématiquement** dans les cas suivants :

- Évolution significative du périmètre fonctionnel (nouveau module, nouveau type de données).
- Ajout d'un sous-traitant majeur.
- Changement de finalité ou de base légale.
- Incident de sécurité significatif.
- Modification du cadre réglementaire applicable.

Prochaine révision prévue : mai 2027.

Annexe A — Documents de référence

- [Règlement RGPD Bertel](#) (information des personnes concernées)
- [CLAUDE.md](#) — Invariants architecturaux et règles métier
- [docs/SQL_ROLLOUT_RUNBOOK.md](#) — Runbook de déploiement SQL et restauration
- [Base de donnée DLL et API/schema_unified.sql](#) — Schéma de référence (RLS, contraintes, audit)
- [Base de donnée DLL et API/api_views_functions.sql](#) — Vues et fonctions API (authentification, permissions)

Document interne — version 1.0 · Dernière mise à jour : 27 mai 2026 · SPL OTI du SUD · Bertel 3.0